🔒 OpenClaw AI Agent 安全评估报告

> **评估时间**: 2026-03-06
> **评估工具**: OpenClaw Security Detector v0.6.3

---

1. 安全评分

指标	结果
安全评分	**2 / 100** ⚠
风险等级	🔴 **CRITICAL (严重)**
合规等级	**D 级**
发现问题	17 项

---

2. 风险清单

🔴 P0 - 严重风险 (5项)

序号	检测项	问题描述	当前值	期望值
1	`gateway.auth.mode`	未启用 Token 认证	`jwt`	`token`
2	`tools.exec.security`	未禁用 exec 直接执行	`allow`	`deny`
3	`tools.elevated.enabled`	未禁用 elevated 工具	`true`	`false`
4	`gateway.bind`	Gateway 未绑定本地	`not set`	`loopback`
5	`agents.defaults.sandbox.docker.network`	禁止使用 host 网络模式	`host`	`none/bridge`

🟠 P1 - 高风险 (7项)

序号	检测项	问题描述	当前值	期望值
6	`gateway.auth.token.length`	Token 长度不足	`0`	`>=32`
7	`session.dmScope`	DM 会话未隔离	`global`	`per-channel-pee`
8	`tools.deny`	未禁用 group:automation	`[]`	包含该项
9	`tools.deny`	未禁用 group:runtime	`[]`	包含该项
10	`tools.fs.workspaceOnly`	文件系统工具未限制工作区	`false`	`true`
11	`tools.exec.ask`	exec 未设置始终询问	`never`	`always`
12	`agents.defaults.sandbox.mode`	未启用沙箱隔离	`off`	`non-main/all`
13	`channels.feishu.dmPolicy`	飞书 DM 策略过于宽松	`open`	`pairing/allowli`

🟡 P2 - 中风险 (3项)

序号	检测项	问题描述	当前值
14	`tools.profile`	工具 profile 过于宽松	`standard`
15	`agents.defaults.sandbox.scope`	沙箱 scope 建议优化	`shared`
16	`agents.defaults.sandbox.workspaceAccess`	沙箱工作区建议只读	`rw`
17	`channels.feishu.groups.general.requireMention`	飞书群组未设置 requireMention	`false`

---

3. 加固建议

3.1 立即执行 (P0)

```
# 1. 启用 Token 认证
openclaw config set gateway.auth.mode token

# 2. 生成安全 Token
export OPENCLAW_TOKEN=$(openssl rand -hex 32)
openclaw config set gateway.auth.token $OPENCLAW_TOKEN

# 3. 绑定本地回环
openclaw config set gateway.bind loopback

# 4. 禁用危险工具
openclaw config set tools.exec.security deny
openclaw config set tools.exec.ask always
openclaw config set tools.elevated.enabled false

# 5. 修复沙箱网络
openclaw config set agents.defaults.sandbox.docker.network bridge
```

3.2 高优先级 (P1)

```
# 6. 隔离 DM 会话
openclaw config set session.dmScope per-channel-peer

# 7. 禁用危险工具组
openclaw config set tools.deny '["group:automation", "group:runtime"]'

# 8. 限制文件系统访问
openclaw config set tools.fs.workspaceOnly true

# 9. 启用沙箱隔离
openclaw config set agents.defaults.sandbox.mode non-main

# 10. 收紧频道策略
openclaw config set channels.feishu.dmPolicy pairing
```

3.3 推荐配置 (P2)

```
# 11. 使用最小化工具 profile
openclaw config set tools.profile messaging

# 12. 优化沙箱 scope
openclaw config set agents.defaults.sandbox.scope session

# 13. 设置只读工作区
openclaw config set agents.defaults.sandbox.workspaceAccess ro

# 14. 启用群组提及
openclaw config set channels.feishu.groups.general.requireMention true
```

3.4 完整安全配置模板

```json
{
  "gateway": {
    "mode": "local",
    "bind": "loopback",
    "auth": {
      "mode": "token",
      "token": "YOUR_32_CHAR_TOKEN_HERE"
    }
  },
  "session": {
    "dmScope": "per-channel-peer"
  },
  "tools": {
    "profile": "messaging",
    "deny": ["group:automation", "group:runtime"],
    "fs": {
      "workspaceOnly": true
    },
    "exec": {
      "security": "deny",
      "ask": "always"
    },
    "elevated": {
      "enabled": false
    }
  },
  "agents": {
    "defaults": {
      "sandbox": {
        "mode": "non-main",
        "scope": "agent",
        "workspaceAccess": "ro",
        "docker": {
          "network": "bridge"
        }
      }
    }
  },
  "channels": {
    "feishu": {
      "dmPolicy": "pairing",
      "groups": {
        "general": {
          "requireMention": true
        }
      }
    }
  }
}
```

4. 修复后预期效果

修复前	修复后
安全评分: 2/100	安全评分: 90+/100
风险等级: CRITICAL	风险等级: LOW
合规等级: D	合规等级: A
17 项安全问题	0-2 项低风险问题

---

5. 一键加固脚本

```bash
#!/bin/bash
# OpenClaw 一键加固脚本

echo "开始安全加固..."

# P0 修复
openclaw config set gateway.auth.mode token
openclaw config set gateway.auth.token $(openssl rand -hex 32)
openclaw config set gateway.bind loopback
openclaw config set tools.exec.security deny
openclaw config set tools.exec.ask always
openclaw config set tools.elevated.enabled false
openclaw config set agents.defaults.sandbox.docker.network bridge

# P1 修复
openclaw config set session.dmScope per-channel-peer
openclaw config set tools.deny '["group:automation", "group:runtime"]'
openclaw config set tools.fs.workspaceOnly true
openclaw config set agents.defaults.sandbox.mode non-main
openclaw config set channels.feishu.dmPolicy pairing

# P2 修复
openclaw config set tools.profile messaging
openclaw config set agents.defaults.sandbox.scope session
openclaw config set channels.feishu.groups.general.requireMention true

echo "加固完成！请重新运行安全检测验证。"
```

---

6. 检测详情

6.1 认证与访问控制

检测项	风险	说明
gateway.auth.mode	🔴 CRITICAL	未启用 Token 认证模式，存在未授权访问风险
gateway.auth.token	🟠 HIGH	Token 长度不足，容易被暴力破解
session.dmScope	🟠 HIGH	会话隔离策略过于宽松，存在会话混淆风险

6.2 工具权限控制

检测项	风险	说明
tools.profile	🟡 MEDIUM	工具 profile 过于宽松
tools.deny	🟠 HIGH	未禁用 automation 和 runtime 工具组
tools.fs.workspaceOnly	🟠 HIGH	文件系统工具未限制工作区
tools.exec.security	🔴 CRITICAL	未禁用 exec 直接执行
tools.exec.ask	🟠 HIGH	exec 未设置始终询问
tools.elevated.enabled	🔴 CRITICAL	未禁用 elevated 工具

6.3 网络安全

检测项	风险	说明
gateway.bind	🔴 CRITICAL	Gateway 未绑定本地回环地址

6.4 沙箱安全

检测项	风险	说明
agents.defaults.sandbox.mode	🟠 HIGH	未启用沙箱隔离
agents.defaults.sandbox.scope	🟡 MEDIUM	沙箱 scope 建议使用 session 或 agent
agents.defaults.sandbox.workspaceAccess	🟡 MEDIUM	沙箱工作区建议设置为只读
agents.defaults.sandbox.docker.network	🔴 CRITICAL	禁止使用 host 网络模式

6.5 频道安全

检测项	风险	说明
channels.feishu.dmPolicy	🟠 HIGH	飞书 DM 策略过于宽松
channels.feishu.groups.general.requireMention	🟡 MEDIUM	飞书群组未设置 requireMention

---

7. 合规映射

合规标准	相关检测项
等保 2.0	gateway.auth.mode, gateway.auth.token, audit.enabled
OWASP Top 10	tools.exec.security, tools.elevated.enabled
ISO 27001	session.dmScope, sandbox.mode, network.mode

---

8. 后续建议

1. **立即执行 P0 级别加固**，修复严重安全风险
2. **定期运行安全检测**，建议每周一次
3. **启用审计日志**，记录所有配置变更
4. **建立审批流程**，重要操作需人工审核
5. **持续监控告警**，及时发现异常行为

⚠ **警告**: 当前配置存在严重安全风险，建议立即执行 P0 级别加固措施！

---

*报告生成时间*0káka̋ Ꞓóя Ꞓóя̆
*评估工具*0Ồóc̓k̓Ḅ̆wṭ̣ Ṭ̌c̓ảř ồg̣u Ç̣c̓c̓ảḍ̣ ộ̀ỉ ́ỏ̆W̆W̆